
SIH26106 — What We Must Build

Plain-English explanation of the official problem statement

Official title: Development of an AI-Powered Platform for Email Threat Detection and GeoLocation of Fraudulent Sources

Organization: AICTE Cyber Security Cell

Theme: Blockchain & Cybersecurity

Category: Software

Problem Statement ID: SIH26106

The whole idea in one sentence

Build a defensive email-forensics platform that takes a suspicious email, analyzes its language and technical headers, traces the sending infrastructure, connects it to related incidents, warns investigators, and preserves the evidence responsibly.

This is much bigger than a normal spam filter.

1. What problem is SIH describing?

Fraudulent emails are no longer always badly written or easy to spot. Attackers can use:

- AI-generated language that sounds professional
- fake executive or company names
- display-name spoofing
- lookalike domains
- hidden redirects
- forged authentication information
- compromised email accounts
- cloud servers and temporary infrastructure
- proxies, VPNs, TOR, and open relays
- long or manipulated relay chains

A normal spam filter may look at the sender address, a few keywords, or a reputation list. An investigation platform must go further. It must inspect the complete email evidence and help an analyst understand both what the message is trying to do and which infrastructure carried it.

Simple example

A message appears to come from a company director:

From: Director <director@acme.example>
Reply-To: director.finance@gmail.example
Subject: Urgent: change the supplier bank account today

The message asks an employee to transfer money. The visible name looks genuine, but the reply address is unrelated. The routing path shows a cloud server that is not normally used by the company. The platform should identify those facts, explain why they are suspicious, and warn the investigator before anyone acts on the message.

The platform must not simply say “spam.” It should show the evidence behind its conclusion.

2. What does “end-to-end” mean?

The official request is an end-to-end investigation flow:

```
Email arrives
-> preserve the raw evidence
-> parse body, MIME parts, links, attachments, and headers
-> classify language and fraud patterns
-> inspect SPF, DKIM, DMARC, and identity mismatches
-> reconstruct the Received relay path
-> identify the earliest reliable sending node
-> enrich IP and domain information
-> compare with threat intelligence and previous cases
-> calculate risk and explain uncertainty
-> alert the analyst before user interaction
-> show dashboard, map, graph, and case history
-> generate a structured forensic report
-> retain, mask, or delete data according to policy
```

Each step supports the next one. A score without evidence is weak. An IP address without header context is weak. A graph without reliable indicators is weak. The value comes from combining all of them.

3. The six official capability areas

The problem statement can be understood as six connected blocks:

A. Fraudulent-email detection

Use NLP and ML along with explainable security rules to understand suspicious language, impersonation, phishing, payment requests, credential theft, and business email compromise.

B. Header and protocol forensics

Inspect Return-Path, Received, Message-ID, Reply-To, SPF, DKIM, and DMARC. Detect inconsistencies, forged results, and unusual routing.

C. Origin and infrastructure intelligence

Find the earliest reliable sending node and enrich it with IP, location, hosting, proxy, domain, DNS, and related infrastructure information.

D. Identity and campaign correlation

Connect the email with threat intelligence, blacklists, previous incidents, repeated domains, IPs, aliases, reply chains, and related campaigns.

E. Alerts, dashboard, reporting, and case management

Warn analysts quickly, show risk and infrastructure context, draw maps and graphs, create reports, and make historical cases searchable.

F. Privacy and evidence controls

Handle personal data carefully, preserve evidence, record actions, support chain of custody, and provide retention and masking controls.

The rest of this document explains exactly what each block means.

4. Build module 1: evidence intake

What must happen?

The platform needs a safe way to receive the original email evidence, preferably as a raw .eml file. It should preserve the original bytes or an evidence copy, calculate a hash, and record when the evidence entered the system.

It should be able to inspect:

- the complete header section
- plain-text and HTML body parts
- MIME structure
- links and URLs
- attachment names, types, sizes, and hashes
- sender and recipient fields
- timestamps and message identifiers

Attachments must be treated as evidence. They must not be opened or executed automatically.

Terms

.eml: A file containing an email with its headers, body, and possibly MIME parts or attachments.

MIME: The format used to package different parts of an email, such as plain text, HTML, images, and attachments.

IOC: Indicator of compromise. An observable item that may help an investigation, such as an IP address, domain, URL, email address, file hash, or message identifier.

Hash: A fixed fingerprint of data. If the evidence changes, its hash should change. A hash helps demonstrate that the inspected bytes are the same bytes that were preserved.

Why this matters

If only the visible message text is copied, the most useful forensic evidence may be lost. The headers and MIME structure often reveal more than the message wording.

5. Build module 2: NLP and fraud detection

What must happen?

The platform should analyze the subject and body for signals such as:

- urgency and pressure
- impersonation of executives or departments
- requests for money
- changed bank details
- requests for passwords or one-time codes
- requests for confidential information
- fake invoices or payment instructions
- suspicious links and redirects
- language that does not match the claimed sender
- unusual replies or changes in conversation context

NLP and ML in simple words

NLP, or Natural Language Processing: Software that analyzes human language. It can identify words, phrases, intent, urgency, entities, and relationships in a message.

ML, or Machine Learning: A model trained on examples so it can recognize patterns in new emails. The model should be evaluated on data it did not train on.

Classifier: A model that assigns a category to an email, such as legitimate, suspicious, phishing, impersonated, or fraud-related.

TF-IDF: One possible baseline NLP technique. It gives more weight to words that are important in a document and less weight to words that appear everywhere. TF-IDF by itself is only a text feature; it is not a complete SIH26106 solution because it does not trace infrastructure or prove identity.

Do we need to train our own model?

No. The official statement requires an AI/NLP/ML capability, but it does not require the team to create a language model from scratch. It also does not say that an external LLM API is forbidden.

The team can use:

- a pretrained open-source model
- a small classifier trained on suitable labelled data
- an LLM API for language analysis
- a hybrid of local forensic rules, a local model, and an optional API

Training a model from zero is usually unnecessary and would require a very large, carefully prepared dataset. Training a tiny model on a few examples would not prove reliable performance.

What an LLM API can do

An LLM API can be used for the language-understanding layer. It can help with:

- understanding suspicious email language
- detecting urgency and impersonation
- identifying BEC patterns
- classifying phishing or fraud intent
- summarizing why a message is suspicious
- extracting entities and the requested action

For example:

Subject: Urgent supplier bank account change

Body: Transfer the payment to the new account before 4 PM.
Do not call me because I am in a meeting.

A language model could return:

```
classification: business email compromise
risk: high
reasons:
- urgent payment request
- bank-detail change
- executive impersonation pattern
- pressure not to verify independently
```

The model output should be treated as an explanation or advisory signal. It should not be accepted as unquestionable forensic proof.

What an LLM API cannot replace

An LLM should not be the only part of the platform, and it cannot independently prove:

- SPF, DKIM, or DMARC validity
- the real originating IP
- the exact location of an attacker
- whether a domain is authorized
- whether an IP belongs to a VPN, TOR node, proxy, or botnet
- the legal identity of the sender
- a complete chain of custody

Those conclusions need technical evidence, validation, infrastructure intelligence, preserved records, and clear uncertainty.

Recommended hybrid architecture

The safest and most convincing architecture is:

```
Raw_email
|
|-- Local forensic engine
|   - headers
|   - Received hops
|   - SPF/DKIM/DMARC evidence
|   - URLs and attachments
|   - IP/domain intelligence
|   - evidence hash
|
|-- NLP/LLM layer
|   - language understanding
|   - BEC/phishing classification
|   - explanation and summary
|
-> Combined risk result
-> dashboard + alert + forensic report
```

The local forensic engine remains responsible for verifiable technical evidence. The NLP or LLM layer improves language analysis and explanation. If the API is unavailable, the system should still perform its core local analysis and show that the language layer is unavailable rather than silently inventing a result.

API security and privacy rules

If an LLM API is used:

- keep the API key on the server, never in frontend JavaScript
- never commit the key to GitHub or place it in a document

- store it in a protected environment variable or secret manager
- redact personal information before sending message content
- do not send real confidential emails during testing
- use a provider and data policy suitable for the organization
- record which model and provider produced an advisory result
- set timeouts, rate limits, and a clear offline fallback
- show that technical evidence is checked locally and independently

How to explain this to judges

“The system uses a hybrid architecture. Deterministic forensic analysis handles headers, authentication evidence, relay tracing, infrastructure intelligence, and evidence integrity. An NLP/LLM layer analyzes language-level fraud patterns such as phishing, impersonation, and BEC. The model assists classification and explanation, while technical conclusions remain evidence-based and independently verifiable.”

Required categories

The problem statement refers to categories such as:

- legitimate
- suspicious
- impersonated
- phishing
- fraud-related

The system may also use a specific BEC label when the evidence suggests business email compromise.

What is BEC?

BEC, or Business Email Compromise, is a fraud pattern in which a criminal impersonates or takes over a trusted business identity to influence a financial or sensitive action.

Examples:

- “The supplier has changed bank accounts. Pay the new account immediately.”
- “I am in a meeting. Purchase gift cards and send the codes.”
- “Please send the employee salary list to this private address.”
- “Use this new invoice instead of the one already approved.”

Risk score versus confidence

A risk score answers:

How dangerous does this message appear based on the evidence?

A confidence or attribution assessment answers:

How strongly does the evidence support a particular explanation about the source or campaign?

These are different. A message can have a high fraud risk while the actual sender remains unknown.

The system should show reasons, not only a number. For example:

- Reply-To does not match the claimed organization
 - SPF failed or is not aligned
 - urgent bank-detail request detected
 - earliest observed hop belongs to unrelated hosting
 - the same domain appeared in earlier cases
-

6. Build module 3: header and protocol forensics

Email headers are technical evidence. They should be displayed in a way an analyst can understand.

Important fields

From: The claimed sender identity. It can be forged or visually misleading.

Reply-To: The address where replies are directed. A mismatch with From is often suspicious, although legitimate systems can also use different reply addresses.

Return-Path: The envelope return address used for delivery failures. It can reveal a different sending or bounce infrastructure.

Received: A series of records added by mail servers as the message moves through the delivery path.

Message-ID: A message identifier generated by a mail system. It can reveal formatting, domain relationships, or repeated campaign patterns.

SPF: Sender Policy Framework. It checks whether the sending IP is authorized to send mail for a domain under the SPF policy.

DKIM: DomainKeys Identified Mail. It uses a digital signature so a receiving system can check whether signed parts of a message were altered and whether the signing domain is identified.

DMARC: Domain-based Message Authentication, Reporting, and Conformance. It combines domain alignment rules with SPF and DKIM results and tells receiving systems how to handle failures.

What the platform must detect

- From, Reply-To, and Return-Path inconsistencies
- authentication results that do not align with the claimed sender
- forged-looking or contradictory header values

-
- suspicious relay ordering
 - unusual or manipulated Received chains
 - a sending IP that is not authorized for the claimed domain
 - a Message-ID or reply pattern connected to other suspicious cases

Important warning

An email can contain a line that says `spf=pass` or `dkim=pass`. That line is evidence from the message, not automatic proof that the platform independently verified it.

A serious system should distinguish:

1. authentication text copied from the email;
2. a live DNS policy lookup;
3. independent cryptographic verification;
4. whether the authenticated domain aligns with the visible From domain.

Header example

```
From: Finance Director <finance@acme.example>  
Reply-To: acme.payments@gmail.example  
Return-Path: bounce@unrelated-mail.example  
Received: from cloud-host.example (203.0.113.50)  
Authentication-Results: spf=fail; dkim=none; dmarc=fail
```

This combination does not automatically identify the criminal. It does provide several strong reasons to investigate the message as a likely impersonation or BEC attempt.

7. Build module 4: relay-path and origin analysis

What is a hop?

A hop is one mail server or network point that handled the message. The Received header usually records these hops.

A simplified path might look like:

```
Company mail gateway  
  -> regional relay  
  -> cloud-hosted server  
  -> recipient mail server
```

The platform should parse the chain, order the hops, and identify which hop is the earliest reliable external sending point.

Why “last visible IP” is not enough

The last server that delivered the message may only be a relay. It may belong to the recipient's mail provider. The useful question is not always "what was the last IP?" It is:

Which observed hop is the earliest reliable point that is external to the trusted delivery path?

The system should explain how it reached that conclusion and mark uncertainty when headers are incomplete or untrusted.

GeoLocation means infrastructure context

GeoIP: An estimate of the geographic area associated with an IP address.

IP location may provide:

- country
- region
- city
- ISP
- hosting provider
- autonomous system or network owner

This is not a GPS location of a person. It is not proof that the attacker physically sat in that city. Cloud hosting, VPNs, proxies, TOR, mobile networks, and shared infrastructure can make the estimate indirect or misleading.

The correct language is:

"The earliest observed infrastructure is associated with this network and approximate location."

Not:

"The attacker is located at this exact place."

Infrastructure categories

Cloud provider: A company that rents computing infrastructure. Criminals may use it temporarily, but cloud hosting alone does not prove malicious activity.

Proxy: A server that forwards traffic and hides the original client from the next destination.

VPN: A service that routes traffic through another network, often hiding the user's normal network.

TOR: A privacy network that routes traffic through multiple relays. A TOR association is context, not automatic proof of guilt.

Open relay: A mail server that may forward messages for unauthorized senders. It can be abused to hide origin.

Botnet: A group of compromised devices controlled by an operator. Botnets may be used to send messages or route traffic.

The platform should correlate these indicators where reliable data is available and should show uncertainty instead of making absolute claims.

8. Build module 5: domain and infrastructure intelligence

An IP address is only one clue. The platform should also investigate domains and hosting infrastructure.

Required intelligence sources and terms

WHOIS: Registration information about a domain, where available. Privacy services and incomplete records are common.

DNS: The system that maps domain names to records such as IP addresses, mail servers, and policies.

MX record: A DNS record that identifies which servers receive email for a domain.

Registrar: The company through which a domain is registered.

Domain age: How long a domain has existed or been registered. A newly created lookalike domain may be suspicious, but age alone is not proof.

Hosting fingerprint: A combination of infrastructure clues, such as shared IP ranges, nameservers, certificates, mail-server patterns, or hosting providers.

The platform should be able to gather and present:

- domain registration context
- DNS records
- MX records
- nameservers
- hosting provider
- IP ownership
- domain age
- registrar information
- related domains or infrastructure

Lookalike-domain example

A real company may use:

`acme.example`

A fraudulent domain may use a visually similar variation:

`acme.example`

or:

`acme-payments.example`

A detector should not rely only on spelling. It should compare the domain, the authentication results, the registration context, the link target, and the message request together.

Live intelligence versus cached context

A production system may use live lookups, but it must handle:

- timeouts
- rate limits
- unavailable data
- privacy restrictions
- inconsistent provider results
- false positives

Every lookup should record its source and time. A missing result is not the same as a clean result.

9. Build module 6: identity and campaign correlation

One suspicious email is useful. A group of related emails can reveal a campaign.

What should be compared?

- sender domains
- IP addresses
- Reply-To addresses
- aliases
- Message-IDs
- URLs
- attachment hashes
- Received-hop patterns
- hosting providers
- nameservers
- previous incidents
- blacklist and threat-intelligence matches

What is a campaign?

A campaign is a related set of fraudulent messages or infrastructure that appear to be part of the same operation or pattern.

For example, three emails may use different visible sender names but share:

- the same Reply-To address
- the same earliest observed IP
- the same link domain
- similar wording
- the same attachment hash

That relationship can be more valuable than any one indicator.

Graph terms

Node: An entity in the investigation, such as a domain, IP, email address, alias, case, or campaign.

Edge: A relationship between two nodes, such as “sent from,” “replied to,” “shared an IP,” or “used the same attachment.”

Campaign graph: A visual network showing how emails, identities, infrastructure, and incidents are connected.

The graph should use understandable labels and explain why each relationship exists. A line without a reason is not useful evidence.

Investigative source categories

The system should distinguish among:

Compromised account: A genuine account may have been taken over and used by someone else.

Spoofed domain or identity: The message claims to be from an organization or person but does not originate from authorized infrastructure.

Anonymized infrastructure: The message is routed through privacy or hiding services, making the original source less visible.

Direct malicious actor: The available evidence points more directly to infrastructure controlled or operated by the malicious party. This is a strong conclusion and should require strong evidence.

The system should never force one category when the evidence is insufficient.

Confidence and uncertainty

A confidence-aware assessment should say what is known, what is likely, and what is unknown.

Example:

High confidence: Reply-To mismatch and DMARC failure.
Moderate confidence: shared infrastructure with two earlier cases.
Low confidence: physical identity of the sender.
Unknown: whether the cloud account was compromised.

This is more useful than pretending that a risk score proves a person's identity.

10. Build module 7: alerts and analyst dashboard

Real-time or near-real-time

The platform should analyze an email quickly enough to warn an organization before a user opens a link, transfers money, or replies.

This could happen at:

- a mail gateway
- a secure email service
- a mailbox scanning layer
- an analyst upload point
- an incident-response queue

The important goal is early action, not analysis after the damage is complete.

What an alert should contain

A useful alert should show:

- email subject and claimed sender
- classification
- risk score
- top reasons
- authentication status
- suspicious URLs or attachments
- earliest observed infrastructure
- approximate infrastructure context
- related cases or campaign
- recommended action
- uncertainty and limitations

Dashboard functions

An analyst dashboard should make it easy to:

- search cases
- filter by label, risk, domain, IP, or campaign
- open the raw evidence safely
- inspect headers
- view relay paths
- view maps and relationship graphs
- compare historical cases
- export a report
- record an analyst decision

The dashboard is for investigation. It should not hide the evidence behind a single unexplained “AI result.”

11. Build module 8: forensic reporting and case management

Structured forensic report

The report should be understandable to a security analyst and useful for an institution or incident-response team.

A complete report should contain:

- case identifier
- evidence filename and hash
- collection time
- subject and sender information
- relevant headers
- body and MIME findings
- URLs and attachment metadata
- authentication results and verification source
- extracted IPs and domains
- Received-hop reconstruction
- infrastructure and GeoIP context
- risk score and reasons
- confidence and uncertainty
- related cases and campaign links
- analyst notes
- recommended action

-
- evidence-handling history

A report can support law enforcement, but it must not turn an uncertain technical clue into an unqualified accusation.

Case management

A searchable case system should allow investigators to:

- find earlier cases by domain or IP
- group related emails into campaigns
- reopen an investigation
- compare indicators
- record decisions
- see who accessed or changed the evidence
- apply retention and deletion rules

The purpose is to prevent every suspicious email from being investigated as an isolated event.

12. Build module 9: privacy, compliance, and evidence custody

Email contains personal and confidential information. The platform must be designed to investigate safely.

Personal data

Personal data may include:

- names
- email addresses
- phone numbers
- signatures
- employee details
- financial information
- passwords or tokens included in a malicious message
- private message content

The system should collect only what is needed, limit access, and avoid exposing sensitive content in dashboards or reports unnecessarily.

Masking and redaction

Masking: Hiding part of a value, such as showing r****@example.com instead of a complete address.

Redaction: Removing sensitive content from a display or report while preserving the underlying evidence under controlled access.

These controls are useful when reports are shared with people who do not need the complete email.

Retention

Retention: How long evidence and case records are stored.

The platform should allow an organization to define how long raw messages, reports, logs, and derived indicators remain available. Retention should be followed by controlled deletion, not indefinite storage by default.

Logging

A log should record important actions, such as:

- evidence received
- evidence hashed
- case opened
- report generated
- data viewed
- data exported
- evidence masked
- evidence deleted

Chain of custody

Chain of custody: A chronological record showing who handled evidence, when they handled it, what they did, and whether the evidence changed.

A simple custody sequence is:

```
Receive evidence
-> calculate hash
-> store protected evidence
-> record analyst access
-> record analysis and exports
-> preserve report and findings
-> apply approved retention or deletion
```

A SHA-256 hash is helpful, but a hash alone is not a complete chain-of-custody system. The custody history and access controls are also required.

Blockchain clarification

The theme includes Blockchain & Cybersecurity, but the problem does not mean that private email contents should be placed on a public blockchain. If an integrity ledger is useful, it should store a safe evidence fingerprint or event record, not sensitive email content.

13. Full worked example: suspected BEC email

The message

From: CEO <ceo@northstar.example>
Reply-To: ceo-office@gmail.example
Subject: Urgent payment change before 4 PM

Please pay the supplier using the attached new bank details. Do not call me because I am in a meeting.

Step 1: content analysis

NLP and fraud rules identify:

- executive impersonation
- urgency
- payment request
- changed bank details
- pressure not to verify independently

Possible classification: fraud-related / BEC / impersonation.

Step 2: header analysis

The system finds:

- visible From domain: northstar.example
- Reply-To domain: gmail.example
- Return-Path from an unrelated mail system
- authentication failure or alignment mismatch

These findings increase the risk, but they do not independently prove who sent the message.

Step 3: relay analysis

The Received chain shows:

```
Recipient gateway
  <- regional relay
  <- cloud-hosted server
```

The platform identifies the earliest reliable observed external hop and explains which headers support that choice.

Step 4: infrastructure intelligence

The IP and domains are checked for:

- hosting provider
- approximate network location
- domain age
- DNS and MX records
- proxy or anonymization signals
- threat-intelligence matches

If a lookup is unavailable, the result should say “unknown,” not “clean.”

Step 5: campaign correlation

Two earlier cases share the same Reply-To address and earliest observed IP. The graph links the three cases and labels the shared indicators.

Step 6: alert and action

Before an employee transfers money, the system raises a high-risk alert:

Likely BEC impersonation

Reasons: urgent bank-change request, Reply-To mismatch, authentication failure,
unrelated relay infrastructure, related previous cases

Action: hold payment and verify through a trusted separate channel

Step 7: report and custody

The investigator exports a structured report containing the evidence hash, headers, indicators, relay path, related cases, findings, uncertainty, and access history.

The correct conclusion is not:

“The attacker definitely lives in the mapped city.”

The correct conclusion is:

“The message is strongly suspicious and the earliest observed infrastructure is associated with this network and approximate location. The physical identity of the sender is not established.”

14. What the complete system must be able to answer

For any suspicious email, an investigator should be able to answer:

1. What is the message asking the recipient to do?
2. Which language or behavior makes it suspicious?
3. Is it phishing, impersonation, BEC, or another fraud pattern?
4. Do From, Reply-To, Return-Path, and authentication results agree?
5. Which servers handled the email?
6. What is the earliest reliable observed sending node?
7. What network, hosting, domain, and approximate location context is available?
8. Is there evidence of a proxy, VPN, TOR, open relay, botnet, or cloud infrastructure?
9. Has this domain, IP, alias, URL, or attachment appeared before?
10. Is the message related to a wider campaign?
11. How certain is each conclusion, and what remains unknown?
12. Who was warned and what action should be taken?
13. Can the findings be exported as a structured report?
14. Can the evidence be preserved, audited, masked, retained, and deleted safely?

If the platform cannot answer these questions or clearly say “unknown,” it is not yet addressing the full problem statement.

15. Minimum acceptance checklist

A solution aligned with SIH26106 should include:

- safe raw-email evidence intake
- full header and MIME parsing
- language and fraud-pattern analysis
- legitimate, suspicious, impersonated, phishing, and fraud-related classifications
- BEC detection
- URL and attachment indicators
- Return-Path, Received, Message-ID, Reply-To, SPF, DKIM, and DMARC analysis
- sender and authentication alignment checks
- relay-path reconstruction
- earliest reliable sending-node reasoning
- IP, hosting, and approximate GeoIP context
- proxy, VPN, TOR, open-relay, botnet, and cloud correlation where data supports it
- WHOIS, DNS, MX, registrar, domain-age, and hosting intelligence

-
- threat-intelligence and blacklist correlation
 - previous-case and campaign correlation
 - entity or campaign graph
 - risk score with explanations
 - origin or attribution confidence with uncertainty
 - compromised-account, spoofed-domain, anonymized-infrastructure, and direct-actor assessment where justified
 - near-real-time analyst alerting
 - dashboard with search, filters, maps, graphs, and case history
 - structured forensic reports
 - logging and chain-of-custody support
 - privacy policy, retention, masking, and deletion controls
-

16. Common misunderstandings to avoid

It is not only a spam classifier

Spam versus ham is too narrow. The platform must also investigate headers, infrastructure, origin, campaigns, evidence, and response.

It is not enough to inspect the From address

From can be forged, displayed misleadingly, or disconnected from Reply-To and Return-Path.

It is not enough to look up one IP

An IP may be a relay, cloud host, VPN exit, proxy, or recipient gateway. It must be interpreted within the Received chain.

IP GeoLocation is not exact human location

It describes network or infrastructure context. It does not prove where a person was physically located.

Authentication text is not always independent verification

The system must say whether it read a result from the email, performed a live policy lookup, or independently verified a signature.

A high risk score is not identity proof

Risk, source confidence, campaign confidence, and human identity are separate conclusions.

Do not execute suspicious attachments

Inspect metadata and hashes in a controlled process. Do not run unknown files as part of ordinary email analysis.

Do not expose sensitive emails unnecessarily

Use access control, masking, redaction, retention rules, and audit logs.

17. The final mental model

Think of the requested platform as five questions joined together:

1. What is this email trying to make someone do?
2. Does the technical evidence support the claimed sender?
3. Where did the observed message path begin?
4. Is this connected to other suspicious infrastructure or campaigns?
5. How do we warn people and preserve the evidence safely?

A strong solution answers all five with visible evidence, clear uncertainty, and responsible handling of private data.

That is what SIH26106 is asking us to build.

Sources

- Official SIH problem-statement portal: <https://www.sih.gov.in/sih2026PS>
- Accessible SIH26106 text mirror used for the complete problem-statement wording: <https://sih2026.vuce.in/ps/SIH26106>